“Año de la Esperanza y el Fortalecimiento de la Democracia”

UNIVERSIDAD TECNOLÓGICA DEL PERÚ

Curso:

Curso integrador 1: Sistema software

Tema:

Auditoria al sistema de OrderFast

Docente:

IVAN GUSTAVO HUAMAN TORRES

Integrantes:

Will Smith Ramos Llamocca – U22305797

Espejo Chacaltana Sebastian Imanol – U23266563

Zamora Zamudio Darick Hanssel – U22217326

Ica - Perú – 2026

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
PT2: MANTENIMIENTO DE SOFTWARE DE APLICACIÓN.	
1. Verificar si el diseño de las nuevas aplicaciones o de las modificaciones a los módulos puestos en producción, son revisados y aprobados por la Gerencia de TI. **Resultado: No verificado** **Respuesta:** El segundo avance presenta el diseño de la solución. No se adjuntó una constancia de revisión del docente o del responsable del equipo que permita comprobar su aprobación.	Avance 2 pp. 23-24 §14 Sin acta de aprobación.
2. Verificar e Identificar quienes son los responsables de aprobar cualquier proyecto de desarrollo, implementación o modificación. **Resultado: No verificado** **Respuesta:** El documento identifica a los integrantes del proyecto, pero no precisa quién aprueba los cambios. Para esta etapa basta dejar registrada esa responsabilidad dentro del equipo.	Avance 2 p. 1 Integrantes Sin encargado de aprobación.
3. Verificar si existen procedimientos definidos o estándares, para las etapas de desarrollo de un nuevo sistema o cambios a los ya existentes. **Resultado: Parcial** **Respuesta:** El avance describe un desarrollo iterativo y una arquitectura por módulos. El repositorio separa interfaz, API y lógica de negocio; falta precisar los criterios que el equipo utiliza para dar por terminada cada actividad.	Avance 2 p. 7 §2.6 Repo: README.md L25-33
4. Verificar si cuentan con mecanismos para identificar los requerimientos de seguridad y control interno para cada proyecto de desarrollo o modificación de sistemas de información, previo a su desarrollo. **Resultado: Parcial** **Respuesta:** El requisito RNF01 contempla autenticación, roles y validación de datos. Su aplicación es parcial: la consulta y la cancelación de pedidos de invitados requieren comprobar el derecho de acceso del solicitante.	Avance 2 p. 7 RNF01 Repo: order.routes.ts L22-30

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
5. Verificar e identificar si se incluyen en el diseño de las nuevas aplicaciones o en las modificaciones de sistemas de información, controles de aplicación que garanticen que los datos de entrada y salida estén completos. **Resultado: Parcial** **Respuesta:** El código valida datos con Zod y calcula los importes en el servidor. Falta comprobar la titularidad del pedido antes de devolver información o aceptar una cancelación.	Repo: order. schemas.ts L6-24 Repo: order. service.ts L64-80 Acceso: L186-190, L288-304.
6. Verificar si consideran aspectos básicos de seguridad y control interno del módulo a ser desarrollado o modificado, y estos son evaluados junto con el diseño conceptual del mismo. **Resultado: Parcial** **Respuesta:** Se incorporan autenticación con Supabase y permisos por rol. La revisión del diseño debe incluir también el acceso a cada pedido, porque disponer de su identificador no acredita que pertenezca al solicitante.	Repo: auth. middleware.ts L7-67 Repo: order.routes.ts L22
7. Identificar si existe una metodología estándar para el desarrollo de un plan de pruebas, en donde se incluyan pruebas unitarias, pruebas de aplicación, pruebas de integración y pruebas de carga y estrés, para cada módulo. **Resultado: Parcial** **Respuesta:** En la revisión previa se registraron 30 pruebas aprobadas: 19 de backend y 11 de frontend. Para este avance conviene completar los casos de acceso al pedido desde otra sesión; no se acreditaron pruebas de integración de autorización ni de carga.	Avance 2 p. 7 §2.6 Repo: Pruebas de estados L4-60 Repo: Pruebas de carrito L4-27
8. Verificar si la formulación del procedimiento de prueba y los datos de prueba son revisados y aprobados por el jefe de programación. **Resultado: No verificado** **Respuesta:** No se presentó un registro de revisión de los casos y datos de prueba. En el contexto académico puede documentarse mediante una lista de casos revisada por el equipo y presentada al docente.	Avance 2 pp. 15-16 §7 Sin acta de revisión de pruebas.

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
9. Verificar si se aplican adecuadas medidas de seguridad para prevenir divulgación de información sensitiva durante las pruebas. **Resultado: No verificado** **Respuesta:** Las pruebas unitarias revisadas emplean datos de prueba. No se comprobó la separación de datos y credenciales en todos los entornos utilizados por el equipo.	Avance 2 p. 14 §6.5.6 Repo: Datos de prueba L4-7
10. Verificar que los resultados de las pruebas son revisados y aprobados por el usuario. **Resultado: No verificado** **Respuesta:** No se aportó evidencia de pruebas de aceptación con usuarios. Para el segundo avance corresponde registrar la demostración de las funciones implementadas y las observaciones recibidas.	Avance 2 pp. 15-16 §7 Sin pruebas de aceptación aportadas.

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
PT3: CONTROLES DE PROGRAMAS Y APLICACIONES.	
1. Verificar el conteo de la cantidad de “byte” de los programas fuentes actuales para hacer una comparación rápida entre la cantidad de byte de estos y los autorizados que se trasladaron a producción para alertar en caso de modificaciones. **Resultado: No verificado** **Respuesta:** El repositorio utiliza Git para identificar versiones y cambios. No se comprobó que el despliegue corresponda exactamente al commit revisado; conviene registrar la versión presentada en cada avance.	Repo: commit 4004844 Despliegue no contrastado.
2. Verificar que exista un archivo lóg o bitácora que permita identificar los errores de ejecución de aplicaciones, sistema operativo y BD. **Resultado: Parcial** **Respuesta:** Existe registro de eventos con Pino. Algunas tareas de notificación descartan errores sin registrarlos, lo que dificulta identificar fallas durante las pruebas del proyecto.	Repo: logger.ts L1-15 Repo: order. service.ts L258-276
3. Verificar si han considerado todos los dispositivos de seguridad que fueron recomendados por el fabricante o el programador. **Resultado: No verificado** **Respuesta:** Se identificaron validaciones, autenticación y controles por rol. No se verificó la configuración completa de seguridad de los servicios externos utilizados.	Avance 2 p. 9 §5.1.2 Repo: app.ts L32-44
4. Verificar que exista una persona responsable en el área de TI de revisar periódicamente los archivos lóg o bitácoras de los sistemas. **Resultado: No verificado** **Respuesta:** El material revisado no identifica a un integrante encargado de revisar los errores registrados. Es conveniente asignar esta tarea durante las pruebas de cada avance.	Avance 2 p. 16 §7.2 Sin encargado de revisar bitácoras.
5. Verificar que la institución respete los límites de la capacidad de procesamiento recomendados por el proveedor como: memoria, espacio en disco, procesamiento CPU. Para garantizar el correcto funcionamiento de las aplicaciones informáticas. **Resultado: No verificado** **Respuesta:** No se revisaron métricas ni cuotas de los servicios contratados. Para este avance corresponde comprobar que los recursos disponibles soporten la demostración y las pruebas previstas.	Avance 2 p. 13 §6.5.3 Sin métricas de capacidad.

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
6. Verificar que la institución cuente con un servidor de desarrollo que sea de uso de los programadores para el desarrollo y pruebas de las aplicaciones internas. **Resultado: No verificado** **Respuesta:** El repositorio permite ejecutar pruebas en local y mediante integración continua. No se verificó un entorno separado que reproduzca todas las condiciones del despliegue.	Repo: README.md L35-71 Repo: backend-ci.yml L15-30 Entorno aparte no verificado.
7. Verificar que los programadores no tengan acceso a la línea de comandos, en los servidores de producción y acceso a estos para consultas. **Resultado: No verificado** **Respuesta:** No se inspeccionaron los permisos de las cuentas de despliegue. El equipo debe identificar quién puede publicar cambios y proteger esas credenciales.	Avance 2 p. 14 §6.5.6 Permisos del despliegue sin revisar.
8. Verificar si existe una persona responsable dentro del área de tecnología en cargada de ejecutar programas de diagnóstico de la red institucional. **Resultado: No verificado** **Respuesta:** No se presentó evidencia de diagnósticos de red. Al tratarse de una aplicación alojada en servicios externos, debe distinguirse la conectividad del equipo de la infraestructura administrada por los proveedores.	Avance 2 p. 13 §6.5.4 Sin diagnóstico de red.
9. Verificar que exista un procedimiento de control de cambios de los programas y del traslado del ambiente de desarrollo a producción. **Resultado: Parcial** **Respuesta:** Git y los archivos de integración continua aportan control de versiones y comprobaciones automáticas. Falta documentar quién revisa y publica los cambios de la versión presentada.	Repo: backend-ci.yml L1-30 Repo: frontend-ci.yml L1-36

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
10. Verificar que no exista más de un usuario además del administrador con el perfil de mantenimiento de parámetros de los módulos de las aplicaciones informáticas. **Resultado: No pasó (escritorio); cuentas no verificadas** **Respuesta:** La administración implementada es web; no se identificó una aplicación de escritorio ni un instalador. Esto deja pendiente el requisito docente comunicado para el rol administrador. Debe desarrollarse el cliente de escritorio con las funciones exigidas, conectado a la API y sujeto a sus permisos. No se verificó el número real de cuentas administrativas.	Avance 2 pp. 10-12 §5.2 y §6.1 Repo: App.tsx L41-64 Escritorio: requisito docente comunicado por el solicitante.
11. Comprobar que la custodia de la documentación del software de Aplicación, los software utilitario entre otros estén controlados por personal de tecnología. **Resultado: No verificado** **Respuesta:** Existe documentación en el repositorio. Para este avance debe mantenerse vinculada a la versión presentada y señalar al integrante responsable de actualizarla.	Repo: README.md L25-33 Repo: FLUJO_Y_ MEJORA.md L91-111 Custodia sin acreditar.

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
PT4: ADMINISTRACIÓN DE CAMBIOS DE APLICACIONES INFORMÁTICAS.	
1. Verificar si existe un sistema para el control de requerimientos de usuarios que afecten la estructura de los sistemas de información. **Resultado: Parcial** **Respuesta:** El avance incluye requisitos y matrices de trazabilidad. Falta relacionar los cambios realizados con su requisito, responsable y estado; puede llevarse un registro sencillo de tareas del equipo.	Avance 2 pp. 18-21 §10-12 Sin registro de solicitudes.
2. Verificar el o los tipos de formularios utilizados para el control de cambios **Resultado: No verificado** **Respuesta:** No se presentó un formato de control de cambios. Un registro de incidencias o tareas con descripción, responsable y fecha sería adecuado para el proyecto universitario.	Avance 2 p. 7 §2.6 Sin formato de cambios.
3. Verificar si existen procedimientos definidos para determinar el estatus de cada solicitud para los cambios realizados. **Resultado: No verificado** **Respuesta:** No se documentó cómo se aprueban y cierran las solicitudes de cambio. Conviene definir estados básicos, como pendiente, en desarrollo, en prueba y terminado.	Avance 2 p. 7 §2.6 Sin flujo de aprobación.
4. Verificar el procedimiento para el tratamiento de solicitudes identificadas como urgentes. **Resultado: No verificado** **Respuesta:** No se identificó un procedimiento para cambios urgentes. El equipo debe registrar la corrección, su responsable y la prueba realizada antes de incorporarla a la versión del avance.	Avance 2 p. 7 §2.6 Sin proceso de urgencias.
5. Verificar la existencia de controles para la modificación de programas fuentes y el traslado a producción. **Resultado: Parcial** **Respuesta:** Git permite controlar las modificaciones y existen comprobaciones automáticas. No se revisaron las protecciones de ramas ni los permisos para publicar.	Repo: backend-ci.yml L1-30 Repo: frontend-ci.yml L1-36

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
6. Verificar si se mantiene un registro de cambios en los programas, que indique la fecha en que se realizó, a fin de proveer el orden cronológico exacto del sistema. Asimismo identificar el responsable de realizar el cambio. **Resultado: Parcial** **Respuesta:** Los commits permiten identificar autor, fecha y cambios del código. Falta vincularlos de forma consistente con los requisitos o incidencias que resuelven.	Repo: commit 4004844 Avance 2 pp. 19-21 §11-12
7. Verificar si se requiere de la aprobación y autorización por escrito de la Gerencia de TI, para todas las modificaciones antes de hacer cambios. **Resultado: No verificado** **Respuesta:** No se aportaron registros de aprobación de cambios. En este proyecto la revisión puede corresponder al integrante designado por el equipo o al docente, según las reglas del curso.	Avance 2 pp. 14-16 §7 Sin actas de aprobación.
8. Verificar si los cambios al sistema operacional o programas aplicativos, sus pruebas y resultados, son revisados por el jefe de programación técnica o quien hace sus funciones. **Resultado: No verificado** **Respuesta:** El repositorio contiene pruebas automatizadas. No se acreditó que el equipo revise sus resultados antes de cada publicación.	Repo: backend-ci.yml L15-30 Revisión de resultados no acreditada.
9. Verificar si los usuarios que formularon el requerimiento lo revisan y dan su aprobación a dichos cambios. **Resultado: No verificado** **Respuesta:** No se recibieron registros de conformidad de los usuarios que solicitaron cambios. Las observaciones de las demostraciones del avance pueden servir como evidencia de revisión si quedan documentadas.	Avance 2 pp. 15-16 §7 Sin conformidad de usuarios.
10. Verificar si existen disposiciones para probar los cambios de programas y revisar los resultados con personal de supervisión antes de que dichas revisiones sean trasladadas al ambiente de producción. **Resultado: Parcial** **Respuesta:** La integración continua incluye comprobaciones automáticas, pero no se verificó que deban aprobarse obligatoriamente antes de publicar una versión.	Repo: backend-ci.yml L15-30 Repo: frontend-ci.yml L15-36

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
11. Verificar quienes son los encargados de efectuar los cambios y como se documentan. **Resultado: Parcial** **Respuesta:** Git identifica a los autores de los cambios. El avance no precisa quién revisa o autoriza cada modificación; conviene asignar esas funciones dentro del equipo.	Repo: commit 4004844 Avance 2 p. 1 Integrantes
12. Verificar que las pruebas se realizan en un área o servidor de desarrollo. **Resultado: Parcial** **Respuesta:** Las pruebas revisadas pueden ejecutarse en local y en integración continua. No se comprobó la separación efectiva de cuentas, credenciales y datos respecto del despliegue.	Repo: backend-ci.yml L15-30 Avance 2 p. 14 §6.5.6

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
PT6: DOCUMENTACIÓN TECNICA	
1. Verificar por medio de inventario los nombres de programas y descripción de ellos **Resultado: Parcial** **Respuesta:** El repositorio permite identificar los módulos del sistema. Parte de la documentación menciona como pendientes componentes o pruebas que ya existen; debe actualizarse para describir con precisión el segundo avance.	Repo: README.md L92-134 Avance 2 p. 22 §13.4
2. Verificar por medio de Inventario los nombres de tablas o archivos con su respectiva descripción **Resultado: Parcial** **Respuesta:** El README enumera las entidades y describe sus campos; los modelos de Mongoose definen su estructura. Falta comprobar que ese inventario corresponda por completo a las colecciones y relaciones de la versión desplegada.	Repo: README.md L136-257 Repo: order.model.ts L7-64
3. Verificar la existencia y disponibilidad de diagramas de entidad relación. **Resultado: Parcial** **Respuesta:** El avance contiene modelado del sistema y descripción de los datos. No se acreditó la correspondencia completa entre sus diagramas y las colecciones realmente utilizadas.	Avance 2 pp. 16-17 §8-9 Repo: order.model.ts L7-64
4. Verificar la existencia de manuales de usuario de los aplicativos puestos en producción. **Resultado: Parcial** **Respuesta:** El avance presenta pantallas y explica los flujos principales. El manual puede desarrollarse progresivamente con las funciones disponibles; deberá incorporar el flujo administrativo de escritorio cuando se implemente.	Avance 2 pp. 23-24 §14 Sin manual de escritorio.
5. Verificar si los manuales de usuarios se encuentran autorizados y disponen de fecha de vigencia, con la finalidad de identificar su actualización **Resultado: No verificado** **Respuesta:** No se presentó un manual con fecha y versión identificables. Para esta etapa conviene indicar el avance al que corresponde y mantenerlo actualizado conforme cambien las pantallas.	Avance 2 pp. 23-24 §14 Manual fechado y autorizado no aportado.

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
6. Verificar la existencia de diccionario de datos de las tablas o archivos que conforman los sistemas puestos en producción. **Resultado: Parcial** **Respuesta:** El README contiene un diccionario de campos con tipos, descripciones y relaciones, complementado por los modelos de Mongoose. Falta verificar su correspondencia completa con la versión presentada y mantenerlo actualizado junto con los cambios del código.	Repo: README.md L136-257 Repo: order.model.ts L7-64

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
PT7: CONTROL DE ENTRADAS Y SALIDAS	
ENTRADAS (ORIGEN DE TRANSACCIONES)	
1. Verificar según sistema cuáles y cuántos son los aplicativos que se alimentan de forma automática y manual. **Resultado: Pasó** **Respuesta:** Los datos ingresan mediante los formularios de carta, carrito, checkout y administración, y por las rutas de la API. Estos son los canales identificados en la versión revisada.	Avance 2 p. 23 §14.1-14.2 Repo: App.tsx L19-24
2. Verificar si la estructura de los formularios que se utilizan como base para la captura de información son adecuados y completos de acuerdo a lo requerido por el sistema. **Resultado: Parcial** **Respuesta:** Los formularios cubren el flujo básico de pedido. El checkout no permite aplicar cupones ni registrar el método de pago; este último figura como pendiente para una siguiente iteración en el avance.	Avance 2 p. 22 §13.4 Repo: Checkout Page.tsx L56-141
3. Verificar la existencia de aplicativos que se alimentan por medio de dispositivos magnéticos de entidades externas, asimismo comprobar los mecanismos de control de calidad de los datos. **Resultado: No aplica** **Respuesta:** No aplica al flujo identificado: el proyecto no contempla importación de datos mediante dispositivos magnéticos de otras entidades.	Avance 2 pp. 11-13 §6.2-6.4
4. Verificar e identificar filtros de alertas o mensajes del sistema que permitan controlar la calidad de información que será ingresada. **Resultado: Pasó** **Respuesta:** La API valida las entradas con Zod y devuelve mensajes de error. En la carta se deshabilita la incorporación de productos sin stock.	Repo: validate.ts L8-20 Repo: Product Card.tsx L17-54
5. Verificar según muestra de documentos fuente, aspectos como cifras de control firma de autorización y similares. **Resultado: No aplica** **Respuesta:** No se utilizan documentos físicos con firmas como origen del pedido. En este flujo la autorización debe comprobarse mediante la identidad, la sesión y los permisos del solicitante.	Avance 2 p. 11 §6.2.1 y §6.2.4

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
6. Verificar si existe un control a nivel de perfil de usuarios que ingresan datos para evitar ingreso de datos por usuarios no autorizados. **Resultado: No pasó** **Respuesta:** Existen restricciones por rol en las funciones administrativas. Sin embargo, el código permite consultar pedidos por su identificador y cancelar pedidos pendientes de invitados sin acreditar su titularidad; debe corregirse la autorización en la API.	Repo: order.routes.ts L22-30 Repo: order. service.ts L288-304
7. Verificar que existan restricciones controladas para el uso de diversos dispositivos magnéticos de entrada. **Resultado: No aplica** **Respuesta:** No aplica al alcance del segundo avance: el ingreso de pedidos se realiza mediante formularios web, sin captura desde dispositivos magnéticos.	Avance 2 p. 11 §6.1 y §6.2.1
8. Verificar que cuando se diseñen formas, los campos de datos importantes tengan predefinido un formato de ingreso de datos, con el fin de minimizar errores. **Resultado: Parcial** **Respuesta:** Se definen tipos y formatos de entrada. El arreglo de productos no tiene un máximo explícito por pedido; conviene acotarlo y comprobar cantidades válidas.	Repo: order. schemas.ts L6-24
9. Verificar que existan controles sobre los documentos de propiedad con números de series secuenciales y el ingreso de dichos números al sistema para crear la relación entre ambos. **Resultado: No aplica** **Respuesta:** No aplica al proceso descrito: OrderFast no gestiona documentos de propiedad seriados como origen de las transacciones.	Avance 2 p. 11 §6.2.4
10. Verificar que exista un registro de la fecha de proceso y la fecha de transacción para las transacciones de entrada. **Resultado: Pasó** **Respuesta:** Los modelos de pedidos incorporan fechas de creación y actualización. Esta comprobación se limita a su definición en el código revisado.	Repo: order.model.ts L18-51 Avance 2 p. 10 §5.1.7

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
11. Verificar si a los documentos ingresados, se les asigna una marca de control o sello con la finalidad de asegurase que estos no sean ingresados nuevamente. **Resultado: No aplica** **Respuesta:** No aplica el sellado de documentos físicos. En el flujo digital debe comprobarse que los reintentos de envío no generen pedidos duplicados; esa prueba no quedó acreditada.	Avance 2 p. 23 §14.2 Reintentos sin prueba aportada.
12. Verificar qué mecanismos utilizan para identificar si existen documentos de entrada no ingresados al sistema. **Resultado: No verificado** **Respuesta:** No se presentó una comprobación que contraste los pedidos enviados desde la interfaz con los registrados. Para el avance conviene incluir ese caso en las pruebas del flujo completo.	Avance 2 p. 7 §2.6 Repo: Checkout Page.tsx L45-53
13. Verificar el cumplimiento del artículo de 451 y 455 del Código de Comercio, que relaciona al período de resguardo de la información fuente u original. **Resultado: No verificado** **Respuesta:** No se ha determinado la pertinencia de los artículos legales citados por el modelo. Su cumplimiento no puede calificarse sin identificar primero la norma y la jurisdicción aplicables al proyecto.	Modelo de auditoría: PT7, entrada 13. Norma aplicable no determinada.
14. Comprobar el control utilizado para demostrar que la información a ingresar se encuentra autorizada. **Resultado: No pasó** **Respuesta:** La cancelación de pedidos pendientes de invitados no comprueba la titularidad en el código revisado. Debe validarse la identidad o credencial del invitado antes de modificar el pedido.	Repo: order. service.ts L288-304 Avance 2 p. 21 HU16
15. Identificar si la institución realiza un control de calidad sobre el estado de los documentos que van a ser digitalizados para ser almacenados como imagen. **Resultado: No aplica** **Respuesta:** No aplica al alcance identificado: el registro de pedidos no incluye digitalización de documentos fuente.	Avance 2 p. 11 §6.2.1 y §6.2.4

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
16. Verificar qué procedimientos existen para el manejo de errores con el fin de proporcionar al personal usuario instrucciones para la corrección de errores en los documentos fuentes. **Resultado: Parcial** **Respuesta:** La API valida datos y devuelve errores. Falta registrar cómo se corrige una entrada rechazada y comprobar que el usuario pueda continuar sin perder información válida.	Repo: validate.ts L8-20 Repo: errorHandler.ts L15-48
17. Revisar los tipos de errores y las razones de su ocurrencia con el fin de determinar si los problemas son ocasionados por el programa o por ingreso incorrecto de datos. **Resultado: Parcial** **Respuesta:** Existen validadores y pruebas de reglas de negocio. No se revisó un registro de incidencias que permita separar errores del programa de errores de ingreso.	Repo: order. schemas.ts L6-24 Repo: Pruebas de estados L4-60
18. Verificar si se obtiene una copia del LOG que registra el sistema en relación a las entradas de datos. **Resultado: No verificado** **Respuesta:** Se identificó un mecanismo de registro de eventos. No se obtuvo una bitácora del despliegue que permita verificar qué entradas quedan registradas y durante cuánto tiempo.	Repo: logger.ts L1-15 Sin bitácora del despliegue.
SALIDAS	
1. Verificar si existe un inventario de reportes, que identifique: nombre del programa, nombre del módulo, unidad destino, frecuencia de emisión y medio de emisión. **Resultado: Parcial** **Respuesta:** Se identifican pantallas de seguimiento y respuestas de la API. El avance no presenta un inventario de salidas con sus usuarios destinatarios; puede documentarse para las funciones implementadas.	Avance 2 p. 24 §14.3-14.4 Sin inventario de salidas.
2. Verificar el proceso de distribución de los reportes de manera que se envíen al personal autorizado. **Resultado: No pasó** **Respuesta:** La consulta del pedido devuelve información a quien conoce el identificador, sin comprobar titularidad. Esto es coherente con el acceso desde incógnito comunicado por el solicitante; la API debe autorizar la consulta antes de entregar los datos.	Repo: order.routes.ts L22 Repo: order. service.ts L186-190

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
3. Verificar el área donde se resguardan los reportes confidenciales de manera que el personal no autorizado no pueda tener acceso a ellos. **Resultado: No pasó** **Respuesta:** La información del pedido no queda limitada a su titular o al personal autorizado. Debe aplicarse autorización en el servidor y devolver únicamente los datos necesarios para cada usuario.	Avance 2 p. 7 RNF01 Repo: order. service.ts L186-190
4. Comprobar que se eliminen de forma inmediata los archivos de salida, no finalizados cuando sean confidenciales. **Resultado: No verificado** **Respuesta:** No se identificó un flujo de generación de archivos temporales confidenciales en las funciones revisadas. El tratamiento de otros archivos del entorno no fue inspeccionado.	Avance 2 p. 13 §6.4 Archivos del entorno sin revisar.
5. Verificar que exista un responsable de efectuar un análisis general de los reportes con el objeto de determinar si hay reportes que puedan ser eliminados, fusionados, reagrupados, simplificados, o si se requiere nuevos reportes. **Resultado: No verificado** **Respuesta:** No se identificó al responsable de revisar las salidas del sistema. Para el segundo avance esta tarea puede asignarse a un integrante que contraste las pantallas con los requisitos.	Avance 2 pp. 14-16 §7 Sin responsable de salidas.
6. Evaluar quién ejerce la función de control de calidad en los reportes emitidos. **Resultado: No verificado** **Respuesta:** No se aportó evidencia específica de pruebas de las salidas. Deben comprobarse el detalle, el total y el estado del pedido, además de quién puede consultarlos.	Avance 2 pp. 15-16 §7 Sin evidencia de pruebas de salidas.
7. Verificar si los encabezados de cada reporte incluyen los siguientes aspectos: fecha de generación, nombre del programa, período cubierto de proceso, titulo descriptivo del contenido del reporte, usuario que generó, número de identificación del programa, número de página, etc. **Resultado: Parcial** **Respuesta:** El seguimiento muestra identificador, productos, importes, estado e historial del pedido. No se verificó un formato de reporte documental para todas las salidas previstas.	Avance 2 p. 24 §14.3 Repo: OrderTracking Page.tsx L48-84

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
8. Verificar que se etiquete cada reporte o grupo de reportes de manera que se indique en el nombre del usuario, destino y el área o departamento al que pertenece. **Resultado: No verificado** **Respuesta:** No se presentó un catálogo con destinatarios y clasificación de las salidas. En las pantallas actuales debe quedar definido qué información corresponde al cliente, al personal y al administrador.	Avance 2 pp. 9-10 y 24 §5.1.2, §5.1.7 y §14 Sin catálogo de destinatarios.
9. Verificar la existencia de códigos que identifiquen el nivel de confidencialidad del reporte. **Resultado: No verificado** **Respuesta:** No se documentó una clasificación de los datos mostrados. Conviene distinguir la carta pública de la información de pedidos y clientes que requiere control de acceso.	Avance 2 p. 7 RNF01 Sin clasificación de datos.
10. Verificar cuál es el procedimiento para la destrucción de reportes sobrantes o que no estén en uso. **Resultado: No verificado** **Respuesta:** No se identificó un procedimiento de conservación o eliminación de reportes. Su definición puede incorporarse cuando se complete ese módulo; los pedidos existentes sí requieren reglas de conservación claras.	Avance 2 p. 13 §6.4 Sin política de conservación.
11. Verificar que mecanismos de control utilizan para producir únicamente la cantidad requerida de reportes solicitados. **Resultado: No verificado** **Respuesta:** No se acreditó un control de distribución de reportes. En la versión revisada debe priorizarse que cada consulta muestre únicamente la información autorizada.	Repo: order.routes.ts L12-22 Distribución no acreditada.
12. Evaluar el nivel de satisfacción de los usuarios respecto a la estructura de los reportes y a la confidencialidad de la información generada. **Resultado: No verificado** **Respuesta:** No se realizaron encuestas ni entrevistas a usuarios sobre estas salidas. Las pruebas del siguiente avance pueden recoger observaciones sobre claridad, utilidad y privacidad de la información.	Avance 2 p. 7 RNF04 Sin encuestas ni entrevistas.

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
PT8: ADMINISTRACIÓN DE BASE DE DATOS.	
1. Verificar qué mecanismos o herramientas usa el Administrador de Base de Datos (DBA) para supervisar y administrar la Base de Datos. **Resultado: Parcial** **Respuesta:** El proyecto utiliza MongoDB Atlas y Mongoose. No se inspeccionó la consola del proveedor ni las herramientas que emplea el integrante responsable de la base de datos.	Avance 2 p. 10 §5.2 Repo: db.ts L10-30
2. Verificar el procedimiento utilizado para definir el nivel de acceso de los usuarios. **Resultado: Parcial** **Respuesta:** La API diferencia operaciones por rol. No se revisaron las cuentas ni los privilegios configurados directamente en MongoDB Atlas.	Repo: auth. middleware.ts L60-67 Privilegios de Atlas sin revisar.
3. Verificar si únicamente el Administrador de Base de Datos tiene privilegios a nivel de administrador para hacer cambios a la base de datos. **Resultado: No verificado** **Respuesta:** No se comprobó quién dispone de permisos administrativos en la base de datos. El equipo debe identificar esas cuentas y limitar el acceso a quienes lo necesitan.	Avance 2 p. 10 §5.2 Cuentas de BD sin inventario.
4. Verificar los diferentes tipos de usuarios que tienen acceso a la Base de Datos, e identificar su clasificación por medio de la siguiente segmentación: 4.1 Usuarios que modifican la estructura 4.2 Usuarios que modifican los datos 4.3 Usuarios operativos 4.4 Usuarios técnicos **Resultado: No verificado** **Respuesta:** No se obtuvo un inventario de cuentas y permisos de la base. Para el avance conviene distinguir quién modifica la estructura, quién utiliza datos de prueba y qué permisos tiene la aplicación.	Avance 2 pp. 9-10 §5.1.2 y §5.2 Cuentas de BD y permisos sin revisar.

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
5. Verificar que el Administrador de Base de Datos disponga de procedimientos escritos para la restauración de la Base de Datos, en caso de una destrucción total o parcial. **Resultado: No verificado** **Respuesta:** No se aportó una prueba de restauración. Es recomendable documentar un respaldo y una recuperación con datos de prueba para proteger el trabajo del equipo.	Avance 2 p. 15 Entregables Sin guía ni prueba de restauración.
6. Verificar que el usuario y clave del BDA se registre en un sobre lacrado y éste se resguarde en un lugar seguro. **Resultado: No verificado** **Respuesta:** No se verificó cómo se custodian las credenciales de administración. El equipo debe utilizar un mecanismo seguro y acceso restringido; no es necesario adoptar literalmente el sobre físico descrito por el modelo.	Avance 2 p. 14 §6.5.6 Custodia de credenciales sin verificar.
7. Verificar que el Administrador de Base de Datos sea responsable de la integridad de la Base de Datos y desarrolle reglas de validación y acceso. **Resultado: Parcial** **Respuesta:** Los modelos y servicios incluyen validaciones de datos. Falta precisar qué integrante revisa la integridad de la base y coordina los cambios de sus estructuras.	Repo: order.model.ts L7-64 Repo: order. schemas.ts L6-24
8. Verificar que el Administrador de Base de Datos documente cualquier cambio que se realice a la Base de Datos. **Resultado: Parcial** **Respuesta:** Git conserva los cambios de los modelos. No se presentó un registro que explique cómo se aplican esos cambios a los datos utilizados en el despliegue.	Repo: commit 0f92bc7 Repo: order.model.ts L7-64
9. Verificar que el Administrador de Base de Datos administra el diccionario de datos. **Resultado: Parcial** **Respuesta:** El README incluye un diccionario de campos y los modelos aportan restricciones de datos. No se identificó al integrante responsable de mantener esa documentación ni se acreditó su actualización completa respecto del despliegue.	Repo: README.md L136-257 Responsable y actualización sin acreditar.

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
10. Verificar que el Administrador de Base de Datos es el responsable de la seguridad global de la Base de Datos. **Resultado: No verificado** **Respuesta:** No se identificó formalmente a un responsable de la seguridad de la base. En el proyecto universitario puede asignarse esa función a un integrante, sin exigir un puesto empresarial independiente.	Avance 2 pp. 1 y 10 Integrantes y §5.2 Sin responsable designado.
11. Verificar si el Administrador de Base de Datos tiene control para que no se realicen pruebas en la Base de Datos en producción, sino que se disponga de diferentes ambientes para este fin. **Resultado: No verificado** **Respuesta:** No se inspeccionó la separación entre datos de prueba y datos del despliegue. Debe comprobarse antes de ejecutar pruebas que modifiquen registros.	Repo: db.ts L10-30 Avance 2 p. 14 §6.5.6 Entornos sin verificar.
12. Verificar que los usuarios no tengan acceso directo a la Base de Datos, sino que el acceso sea a través del servidor de aplicaciones. **Resultado: Parcial** **Respuesta:** La interfaz utiliza la API para consultar y modificar datos. No se verificaron las restricciones de red ni los permisos de acceso directo configurados en MongoDB Atlas.	Repo: api.ts (frontend) L24-35 Repo: db.ts L10-30
13. Verificar si existen pruebas que involucren atentados deliberados para destruir o modificar la Base de Datos, considérense atentados tanto internos como externos. Estos simulacros deben de ser desarrollados por el Administrador de Base de Datos. Las destrucciones descritas en los simulacros deben de ser llevados a cabo por personal autorizado o no autorizado que trate de cambiar la Base de Datos, modificar los programas de la Aplicación, sustraer copia de la Base de Datos o del diccionario de datos, etc. **Resultado: No verificado** **Respuesta:** No se realizaron pruebas destructivas. Para este avance corresponde verificar permisos y recuperación en un entorno de prueba, con datos descartables y autorización del equipo.	Avance 2 p. 7 §2.6 Sin simulacros destructivos.

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
14. Verificar que solo el usuario de administrador tenga el privilegio de acceso a las tablas de usuarios y contraseñas. **Resultado: No verificado** **Respuesta:** La autenticación se delega en Supabase y la aplicación administra sus propios perfiles. No se revisaron los privilegios efectivos sobre usuarios y credenciales en las consolas de los proveedores.	Repo: auth. middleware.ts L7-19 Repo: user.model.ts L6-16
15. Verificar si el software de Base de Datos utilizado en la institución cuenta con tablas de registros de auditoría para revisar los eventos que tiene registrados. **Resultado: No verificado** **Respuesta:** No se inspeccionaron los registros de auditoría disponibles en MongoDB Atlas ni su configuración. Su ausencia no puede deducirse del código de la aplicación.	Avance 2 p. 10 §5.2 Auditoría de Atlas sin revisar.
16. Verificar en las tablas de registros de auditoría de la Base de Datos las acciones de intentos de conexión, acceso a los objetos y accesos a la base. **Resultado: No verificado** **Respuesta:** No se obtuvieron registros de conexión o acceso a la base. Por ello, este control queda sin verificar en el alcance de la revisión.	Avance 2 p. 10 §5.2 Registros de conexión y acceso no aportados.
17. Verificar las acciones que el Administrador de la Base de Datos realiza con las tablas de registros de auditoría de la base, para corregir posibles fallas o accesos no autorizados. **Resultado: No verificado** **Respuesta:** No se presentaron registros que permitan comprobar acciones correctivas posteriores a eventos de acceso a la base.	Avance 2 p. 16 §7.2 Sin registros de acciones sobre eventos de BD.
18. Verificar que el parámetro para permitir auditoría a la Base de Datos tenga el valor que equivale o permite auditoría. **Resultado: No verificado** **Respuesta:** No se inspeccionó la configuración de auditoría del proveedor. El equipo debe comprobar qué registro de eventos está disponible en el servicio utilizado.	Avance 2 p. 10 §5.2 Configuración de auditoría de Atlas sin revisar.

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
19. Verificar que existan controles mínimos en la seguridad de las tablas: por ejemplo: 19.1 Clase de transacción: un usuario específico puede quedar limitado a ciertos tipos de transacciones. 19.2 Programas: los usuarios pueden estar restringidos al empleo de ciertos programas de proceso. 19.3 Grupos de archivos: se les puede permitir a los usuarios el acceso, la modificación, y el borrado únicamente de archivos específicos. 19.4 Archivos completos: puede ser dado el acceso a un conjunto completo de archivos. 19.5 Registros individuales: el acceso puede estar limitado a registros específicos. 19.6 Grupos de registros: a usuarios específicos se les puede permitir o restringir el uso de determinados grupos de registro. 19.7 Diversos controles de contraseña: los usuarios pueden quedar limitados al uso de solo ciertas porciones de la Base de Datos. 19.8 Diversos controles de terminales: varias terminales pueden quedar sujetas a un código de transacciones para restringir su acceso a ciertas porciones de la base de datos. 19.9 Controles del circuito: ciertos circuitos en la red de comunicación de datos pueden quedar limitados a ciertas porciones de la base de datos. **Resultado: Parcial** **Respuesta:** La aplicación diferencia roles, pero la consulta y cancelación de pedidos requieren autorización por registro. Los permisos propios de MongoDB no fueron inspeccionados; un identificador de pedido no sustituye la comprobación del titular.	Repo: order.routes.ts L22-30 Repo: order. service.ts L288-304 Permisos de BD sin revisar.

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
PT9: SEGURIDAD LÓGICA.	
1. Verificar que el software de comunicaciones exige código de usuario y contraseña para su acceso. **Resultado: No pasó** **Respuesta:** Las rutas protegidas verifican tokens de Supabase y aplican roles. La consulta de pedidos por identificador constituye una excepción: no comprueba que el solicitante tenga derecho a ver ese pedido.	Repo: auth. middleware.ts L22-43 Repo: order.routes.ts L22
2. Verificar si los usuarios no pueden acceder a ningún sistema, sin antes haberse autenticado correctamente en la red institucional. **Resultado: No pasó** **Respuesta:** Se reportó que el mismo enlace permite consultar el pedido desde incógnito; no se reprodujo ese enlace concreto. El código revisado es consistente con el reporte porque la consulta no exige acreditar titularidad. Debe validarse al titular en la API o vincular el pedido de invitado a una credencial de sesión. Para impedir el acceso al copiar solo el enlace, esa credencial debe quedar fuera de la URL; un enlace que incluya el secreto también funcionaría en incógnito.	Avance 2 p. 24 §14.3 Repo: order.routes.ts L22 Repo: order. service.ts L186-190 Incógnito: reporte del solicitante.
3. Verificar si se inhabilita al usuario después de ingresar la contraseña después un número determinado de intentos fallidos. **Resultado: No verificado** **Respuesta:** No se inspeccionó la política de intentos fallidos configurada en Supabase. Debe verificarse con una cuenta de prueba, sin asumir que el proveedor tiene activado un bloqueo específico.	Repo: LoginPage.tsx L21-24 Política externa no inspeccionada.
4. Verificar que el sistema operativo obliga a cambiar la contraseña periódicamente. **Resultado: No verificado** **Respuesta:** No se revisó la caducidad de contraseñas del proveedor. El criterio del modelo debe contrastarse con la política de autenticación definida para el proyecto.	Avance 2 p. 9 §5.1.2 Caducidad en Supabase no inspeccionada.

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
5. Verificar que la contraseña no sea menor a 8 caracteres y que sea una combinación de números y letras, entre ellos mayúsculas y minúsculas. **Resultado: No verificado** **Respuesta:** No se comprobó la política efectiva de contraseñas en Supabase. El equipo debe revisar sus requisitos y contrastarlos con el formulario de registro.	Repo: LoginPage.tsx L21-24 Política efectiva de Supabase no comprobada.
6. Verificar que las contraseñas no son mostradas en pantalla cuando se ingresan. **Resultado: Pasó** **Respuesta:** El formulario de acceso utiliza un campo de tipo password, que oculta los caracteres mientras se escribe la contraseña.	Repo: LoginPage.tsx L45-52
7. Verificar si durante el procedimiento de identificación, los usuarios son informados de cuándo fue su última conexión para ayudar a identificar potenciales suplantaciones o accesos no autorizados. **Resultado: No pasó (mejora para otra etapa)** **Respuesta:** No se identificó un aviso de última conexión. Su incorporación puede evaluarse como mejora de seguridad; no se acreditó que sea un entregable exigido para este segundo avance.	Repo: LoginPage.tsx L17-65 Repo: AuthProvider .tsx L23-51
8. Verificar que existe software para llevar estadísticas que incluyan tasas de errores y de retransmisión. **Resultado: Parcial** **Respuesta:** Existen registros con Pino y comprobaciones de disponibilidad. Algunas notificaciones descartan errores sin registrarlos; debe corregirse ese manejo para facilitar las pruebas y el diagnóstico.	Repo: logger.ts L1-15 Repo: order. service.ts L258-276
9. Verificar que los equipos puedan validar la identificación electrónica de las terminales que se agregan a la red. **Resultado: No verificado** **Respuesta:** No se inspeccionó la red ni la identificación de los equipos conectados. Este control de infraestructura no puede valorarse a partir de la aplicación web presentada.	Avance 2 p. 13 §6.4-6.5 Red y equipos sin revisar.

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
PT12: SEGURIDAD INFORMÁTICA	
1. Verificar que existan políticas de seguridad, definidas y aprobadas por la Administración. **Resultado: No verificado** **Respuesta:** El avance contiene requisitos de seguridad, pero no un documento de reglas acordadas por el equipo. Para esta etapa conviene definir quién administra accesos, credenciales y datos de prueba.	Avance 2 pp. 7 y 14 RNF01 y §6.5.6 Sin política aprobada.
2. Verificar que las políticas de seguridad contengan, elementos como: confidencialidad, integridad y disponibilidad. **Resultado: Parcial** **Respuesta:** Se declaran objetivos de protección y confiabilidad. La confidencialidad no queda suficientemente cubierta mientras se pueda consultar un pedido sin acreditar titularidad.	Avance 2 p. 7 RNF01, RNF03 y RNF08 Repo: order.routes.ts L22
3. Verificar que las políticas contengan mecanismos para medir: riesgos y amenazas, análisis de riesgos, plan de seguridad, controles preventivos y correctivos, plan de contingencia, biometría, firma digitales, protección y defensas. **Resultado: No verificado** **Respuesta:** No se presentó una evaluación de riesgos del proyecto. Para el segundo avance puede elaborarse una relación breve de riesgos, responsables y medidas, centrada en las funciones ya implementadas.	Avance 2 pp. 13-14 §6.5 Sin evaluación formal de riesgos.
4. Identificar qué mecanismos utilizan para no revelar la información a personas no autorizadas, acceso a información confidencial y protección de datos. **Resultado: No pasó** **Respuesta:** La consulta devuelve datos del pedido y de entidades relacionadas sin comprobar titularidad. Debe restringirse al propietario o al personal autorizado y limitar la información enviada; el reporte de acceso desde incógnito refuerza la necesidad de revisar este control.	Repo: order.routes.ts L22 Repo: order. service.ts L186-190 Incógnito: reporte del solicitante.

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
5. Verificar como controlan las amenazas externas, como hackers o espías. **Resultado: Parcial** **Respuesta:** Existen validaciones, autenticación y permisos por rol. Falta la autorización por pedido; la limitación de solicitudes figura como pendiente en el avance y debe planificarse según la exposición del servicio.	Repo: app.ts L32-44 Avance 2 p. 22 §13.4
6. Verificar la existencia de procedimientos para controlar riesgos como por ejemplo: ausencia de planes de contingencia, ausencia de políticas de seguridad y estrategias, ausencia de procedimientos para modificación de aplicaciones, programadores con acceso irrestricto a los datos, seguridad débil en accesos a Internet, e-mail, Inadecuada segregación de funciones, falta de procedimientos de contingencia, débiles políticas para la creación de contraseñas, ausencia de bitácoras de seguridad y falta de oficiales de seguridad. **Resultado: No verificado** **Respuesta:** No se documentó cómo actuar ante pérdida de acceso, exposición de credenciales o interrupción del servicio. Para el proyecto basta definir responsables y pasos de recuperación proporcionados a su alcance.	Avance 2 pp. 13-14 §6.5 Sin plan de respuesta y recuperación.
7. Verificar la existencia de procedimientos para controlar las amenazas, por ejemplo: Sniffing, Frame Spoofing, Crack, Hacking a un Website, Ingeniería Social, Caballos de Troya, Ataques de Denegación de servicios, Fake Mail. **Resultado: Parcial** **Respuesta:** Se identificaron controles técnicos básicos, pero no un registro de pruebas frente a solicitudes no autorizadas. Conviene priorizar esos casos antes de ampliar las funciones públicas.	Repo: app.ts L32-44 Repo: order.routes.ts L22-30
8. Verificar si están definidas las funciones de los cargos siguientes: el DBA (Data base administrator - administrador de base de datos), el NA (Administrador de red - Network administrator) y el SA (Administrador de sistema - System administrator). Dicha verificación es con la finalidad de no entrar en conflicto de funciones. **Resultado: No verificado** **Respuesta:** No se identificó una asignación expresa de responsabilidades sobre datos, despliegue y seguridad. Estas funciones pueden distribuirse entre los integrantes, sin exigir cargos empresariales separados.	Avance 2 pp. 1 y 15-16 Integrantes y §7.2 Funciones no asignadas.

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
9. Verificar que tipo de sistemas de detección de intrusos (IDS) utilizan según las características siguientes: 9.1 HIDS (*HostIDS*): un IDS vigilando un único ordenador y por tanto su interfaz corre en modo no promiscuo. La ventaja es que la carga de procesado es mucho menor. 9.2 NIDS (*NetworkIDS*): un IDS basado en red, detectando ataques a todo el segmento de la red. Su interfaz debe funcionar en modo promiscuo capturando así todo el tráfico de la red. 9.3 *DIDS (DistributedIDS*): sistema basado en la arquitectura cliente servidor compuesto por una serie de NIDS (IDS de redes) que actúan como censores centralizando la información de posibles ataques en una unidad central que puede almacenar o recuperar los datos de una base de datos centralizada. La ventaja es que en cada NIDS se puede fijar unas reglas de control especializándose para cada segmento de red. Es la estructura habitual en redes privadas virtuales (VPN) **Resultado: No verificado** **Respuesta:** No se inspeccionaron servicios de detección de intrusiones. Su necesidad debe evaluarse según el despliegue y las capacidades del proveedor; no se considera automáticamente una exigencia del segundo avance.	Avance 2 pp. 10-14 §5.2 y §6.5 Servicios IDS sin inspección.

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
10. Verificar como administran los perfiles de los responsables de la seguridad, ó al menos que cumplan con las actividades siguientes: SecAdmin: Administrador de seguridad. Administra altas, bajas, y cambios de perfiles de usuarios. Otorga permisos de acceso a los recursos y puede auditar a los usuarios. System Administrator: Instalación de software de base, administración de recursos (capacidad, performance, etc.). Sin acceso irrestricto a los datos. Con utilización controlada de utilitarios sensitivos. Network Administrator: Atiende y monitorea la red. Instala y configura los componentes de software y hardware. Resuelve problemas de ambiente y conexiones. DBA: Administra la base de datos. Genera las estructuras, los índices, el diccionario de datos, administra los espacios, etc. Desarrollador: Puede modificar programas, compilar en librerías de test, y probar con datos de prueba. EL desarrollador puede tener línea de comandos restringidos. Implementador: Debe pasar los programas de desarrollo a producción mediante un mecanismo que asegure la transparencia. Puede intervenir operaciones. El implementador puede tener línea de comandos restringidos. Operador del sistema: Puede operar el sistema, encenderlo, apagarlo, descolgar usuarios por terminales, etc. El operador no debe tener línea de comandos. Usuarios finales: Solo deben acceder a las aplicaciones mínimas que necesitan para desarrollar su tarea diaria. **Resultado: Parcial** **Respuesta:** La aplicación diferencia roles de cliente, personal y administrador. No se comprobó la distribución real de privilegios de infraestructura entre los integrantes; conviene documentarla y evitar cuentas administrativas compartidas.	Avance 2 p. 9 §5.1.2 Repo: user.model.ts L3-16 Permisos del proveedor sin verificar.
11. Verificar que la seguridad informática y de datos, se aborda un proceso de seguridad recomendado a utilizar según las siguientes herramientas: un Firewall o combinación de ellos, Proxy es un sistema de detección de intrusos o IDS. sistemas de actualización automática de software, sistemas de control de la integridad de los servidores, paquetes, etc. **Resultado: No verificado** **Respuesta:** No se inspeccionaron los controles de red y servidores de los proveedores. El equipo debe verificar las opciones disponibles y proteger las cuentas que administra directamente.	Avance 2 pp. 13-14 §6.5.3-6.5.6 Controles del proveedor sin revisar.

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
12. Verificar como se administra la información según los lineamientos establecidos en la Política de Seguridad de Información, aprobada por la Alta Dirección. **Resultado: No verificado** **Respuesta:** No se presentó una política de manejo de información del equipo. Deben definirse reglas básicas de acceso, uso de datos de prueba y cuidado de credenciales.	Avance 2 pp. 7 y 14 RNF01 y §6.5.6 Sin política del equipo.
13. Verificar como establecen y mantienen los procedimientos que aseguren la integridad, confidencialidad, exactitud y disponibilidad de la información de la empresa, en niveles concordantes con la importancia que se merece. **Resultado: Parcial** **Respuesta:** Existen validaciones y reglas de negocio. La consulta y cancelación de pedidos requieren acreditar titularidad, y los fallos de notificación deben registrarse para comprobar la continuidad del flujo.	Repo: order. service.ts L258-304 Repo: order.routes.ts L22-30
14. Verificar los riesgos a que pueda estar expuesta la información, ya sea durante su almacenamiento, manipulación o comunicación, y recomendar los controles más adecuados según criterios de costo/beneficio, para eliminarlos o reducir sus efectos. **Resultado: Parcial** **Respuesta:** Se identificaron riesgos de consulta de pedidos, cancelación sin titularidad y reservas pendientes. Deben priorizarse por su impacto; las funciones declaradas para otra iteración se registran como pendientes del desarrollo.	Repo: order. service.ts L288-304 Avance 2 p. 22 §13.4
15. Verificar como monitorean y rastrean la actividad de los usuarios administrativos y operativos a fin de detectar y corregir desviaciones en el uso correcto de la información, o en el cumplimiento de las normas y procedimientos asociados a la seguridad de la información. **Resultado: Parcial** **Respuesta:** El código incluye fechas y registros de eventos. No se comprobó una bitácora completa que permita identificar quién ejecutó cada operación administrativa.	Repo: order.model.ts L18-51 Repo: logger.ts L1-15

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
16. Verificar que controles lógicos y físicos se utilizan para asegurar que sólo el personal autorizado pueda acceder a la información, dentro de los niveles de atención. **Resultado: No pasó** **Respuesta:** Las operaciones administrativas aplican roles, pero la consulta y cancelación de pedidos de invitados presentan controles insuficientes. La API debe verificar el permiso sobre cada pedido antes de devolver datos o cambiar su estado.	Repo: order.routes.ts L22-30 Repo: order. service.ts L288-304
17. Verificar que procedimientos operativos y programas computarizados idóneos, probados y autorizados, se pueda acceder, modificar, divulgar, destruir o mantener la Información. **Resultado: Parcial** **Respuesta:** Los servicios centralizan las operaciones y existen pruebas unitarias. Faltan casos de integración que comprueben acceso por titular, otro usuario e invitado sin credencial.	Repo: order. service.ts L186-190 Repo: Pruebas de estados L4-60
18. Verificar el cumplimiento de las políticas de desarrollo de documentación mínima de los procedimientos operativos y aplicaciones, que permitan las operaciones de la empresa bajo una situación de contingencia. **Resultado: No verificado** **Respuesta:** El repositorio conserva código y documentación. No se presentó una guía de recuperación del servicio; para el avance conviene registrar configuración necesaria, responsables y pasos de restauración.	Repo: README.md L35-71 Avance 2 pp. 15-16 §7 Sin guía de recuperación.
19. Evaluar y seleccionar, en coordinación con la unidad de Sistemas tecnológicos, herramientas para apoyar las funciones de la unidad Seguridad de Informática. **Resultado: No verificado** **Respuesta:** Se identificaron herramientas de autenticación y validación, pero no una justificación documentada de todas las decisiones de seguridad. Puede incorporarse al análisis de la solución del proyecto.	Avance 2 pp. 21-22 §13.2 Repo: auth. middleware.ts L7-19

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
20. Verificar el impacto que los cambios en la tecnología puedan ocasionar a la seguridad, y si estos cambios la afectaran, dirigir la transición hacia un nuevo entorno de garantía. **Resultado: Parcial** **Respuesta:** Git y las comprobaciones automáticas permiten revisar cambios. Falta registrar si una modificación afecta permisos, exposición de datos o compatibilidad con los módulos existentes.	Repo: commit 4004844 Repo: backend-ci.yml L15-30
21. Verificar los procedimientos usados para evaluar las políticas en la destrucción de la información, especificando los medios a utilizar, procedimientos a aplicar, y la oportunidad en que se ejecutará. **Resultado: No verificado** **Respuesta:** No se documentó cómo conservar o eliminar datos de prueba y pedidos. El equipo debe definir esas reglas antes de ampliar el uso del sistema con información real.	Avance 2 pp. 13-14 §6.4-6.5 Sin reglas de conservación y eliminación.